

Innhold

Arbeidskrav 1 – NordElektro AS	2
Innledning	2
Task A1 - Bruk av NIST CSF 2.0 i NordElektro	2
1. Govern	2
2. Identify	3
3. Protect	3
4. Detect	4
5. Respond	4
6. Recover	5
Task A2 - IAM, Zero Trust, RBAC og ABAC	5
Task A3.1 – Informasjonseiendelsregister	7
Task A3.2 - Risiko: sårbarhet, trussel aktør og konsekvens for CIA-triaden	7
Sårbarhet	7
Trussel aktør	8
Trussel scenario	8
Vurdering opp mot CIA-triaden	8
Konfidensialitet	8
Integritet	8
Tilgjengelighet	8
Delkonklusjon for A.3	8
Task B – Kryptografipolicy	9
1. Data at Rest	9
Passord – hashing med salt	9
Personnummer – symmetrisk kryptering	9
Transaksjonshistorikk	9
2. Data in Transit – hvorfor TLS 1.3 bør brukes	10
3. Future-Proofing – Perfect Forward Secrecy (PFS)	10
Verktøy	10
Kilder	10

Arbeidskrav 1 – NordElektro AS

Innledning

Jeg vil ta utgangspunkt i caset om NordElektro AS og vil se på hvordan bedriften kan forbedre informasjonssikkerheten mens de er i gang med den digitaliserings fasen. Vi kan tenke oss at NordElektro er en stor virksomhet som har både fysiske butikker, nettbutikker, lagre, kundeservice og sentrale IT-systemer. Dette gjør at de er veldig avhengige av at de digitale løsningene fungerer som de skal, altså stabilt og sikkert for at den daglige driften skal gå som normalt. Samtidig kommer det fram i caset at virksomheten har hatt flere utfordringer. Disse er blant annet at hendelser blir oppdaget for sent, at det er uklart hvem som har ansvar for hva når noe går galt, rutiner for backup og gjenoppretting ikke er gode nok, osv. ...

For å svare på disse utfordringene vil jeg i denne oppgaven bruke **NIST CSF 2.0** som et rammeverk for den overordnede styringen av cybersikkerhet. Jeg vil også ta i bruk Zero Trust og IAM for å se nærmere på hvordan tilgangsstyringen kan bli bedre. I tillegg vil ISO/IEC 27001:2022 bli nevnt som et grunnlag for en mer systematisk risikostyring knyttet til **Click & Collect-løsningen**. Til slutt har jeg valgt å fokusere på Task B, der jeg skal drøfte hvordan kryptografi bør brukes for å beskytte data.

Task A1 - Bruk av NIST CSF 2.0 i NordElektro

NIST CSF 2.0 består av seks sentrale funksjoner: **1. Govern, 2. Identify, 3. Protect, 4. Detect, 5. Respond** og **6. Recover**. Til sammen gir disse et helhetlig rammeverk for hvordan en virksomhet kan jobbe med å styre cyberrisiko. Jeg tenker at for **NordElektro** kan dette være spesielt relevant. Grunnen til dette er fordi selskapet er i en overgang fra en mer tradisjonell IT-sikkerhetsmodell til en mer risikobasert måte å jobbe på.

1. Govern

«Govern» handler om å etablere en tydelig styring, ansvar, viktige prioriteringer og en god sikkerhetskultur. For NordElektro AS er dette et naturlig startpunkt. Jeg tenker dette fordi ansvaret tidligere har vært uklart når hendelser kan ha oppstått. Jeg tenker for eksempel når et system har vært nede har det ikke alltid vært klart hvem som kunne ta de viktige beslutninger. Dette innebærer også for eksempel å varsle butikker eller følge opp med dokumentasjon. Derfor tenker jeg at virksomheten bør først og fremst få på plass en tydelig styringsmodell for informasjonssikkerhet.

Ledelsen må også avklare hvilke roller som har **accountability** og hvilke som har **responsibility**. Accountability handler om et overordnet ansvar mens responsibility handler mest om hvem som utfører oppgavene i praksis. For eksempel:

- IT-sikkerhetsleder har hovedansvar for hendelseshåndtering
- SOC- eller driftspersonell står for den daglige overvåkingen.

I tillegg tenker jeg at NordElektroAS burde bygge en sikkerhetskultur i hele organisasjonen. Sikkerhet kan ikke bare være IT-avdelingens sitt ansvar men må være en del av kulturen og

bli innført i alle grener i selskapet (ansatte, ledelse, osv.) Dette kan innføres for eksempel gjennom tydelige rutiner, opplæring og øvelser. Et annet viktig område er **leverandørstyring**. NordElektro er avhengig av skybaserte betalingstjenester og andre eksterne leverandører. Dette betyr at dersom en av disse kommer i avveie eller blir kompromittert, kan dette føre til konsekvenser. Derfor tenker jeg at virksomheten bør stille tydelige sikkerhetskrav gjennom risikovurderinger, avtaler og jevnlig oppfølging av ansatte.

2. Identify

Identify handler hovedsakelig om å forstå hvilke verdier virksomheten har, hvilke systemer som er kritiske og ikke og hvilke risikoer som er knyttet til disse. I vårt tilfelle er NordElektro avhengig av mange sammenkoblede systemer:

- POS-terminaler i butikk
- sentrale lagersystemer
- kundedatabaser
- betalingsløsninger
- netthandel
- HR-systemer
- logistikkplattformer.

NordElektro bør starte med en systematisk kartlegging av sine eiendeler. Dette gjelder både tekniske og ikke-tekniske. Disse innebærer:

- kundedata, personopplysninger, betalingsinformasjon, POS-utstyr, bærbare enheter, databaser, nettverkssoner, skyløsninger og forretningskritiske prosesser som Click & Collect.

Selskapet bør derfor identifisere hvilke prosesser som er mest kritiske for drift og inntekter. Vi kan tenke oss at for eksempel hvis betalingssystemene i butikken eller den sentrale produktdatabasen går ned i for eksempel en gitt kampanje periode, kan dette føre til stor økonomisk tap og dårlig omdømmet. En ting vi kan gjøre for å forhindre dette er for eksempel å vurdere sannsynlighet opp mot konsekvens. Et system som inneholder persondata og brukes av mange ansatte i hele kjeden, vil ofte få høy prioritet. Dette er fordi både sannsynligheten og konsekvensene kan være store. Et mindre internt støtteverktøy uten sensitive data vil vanligvis få lavere prioritet, som for eksempel en PC som brukes for visning av kølapp.

3. Protect

Protect handler hovedsakelig om å innføre tiltak som både reduserer sannsynligheten for hendelser og begrenser skaden hvis noe skulle skje. I vårt tilfelle, kan NordElektro knytte det til opp mot *CIA-triaden*: **konfidensialitet, integritet og tilgjengelighet**.

Konfidensialiteten i vårt tilfelle kan beskyttes for eksempel ved at kun autoriserte brukere får tilgang til kundedata, personnummer, bestillingsinformasjon og interne systemer. Dette kan innføres ved for eksempel blant annet sterk autentisering, gode passordrutiner, minst mulig tilgang, nettverkssegmentering og kryptering av sensitive data.

Integriteten kan innføres blant annet ved å sørge for at data ikke blir endret uten tillatelse. Dette kan gjøres med rollebasert tilgangsstyring, logging av endringer, kontroll på administrative rettigheter, sikre utviklingsrutiner, validering av input i applikasjoner og patching.

For å beskytte tilgjengelighet, kan NordElektro ha redundans, sikre backup, teste gjenoppretting, DDoS-beskyttelse, overvåkning og tydelige beredskapsrutiner. Dette er viktig fordi butikker får ikke solgt varer når sentrale systemer er nede. I tillegg til dette, bør NordElektro ha jevnlig sikkerhetsopplæring for butikkansatte og andre brukere. Dette kan for eksempel være opplæring i phishing, sosial manipulering, trygg passordbruk, håndtering av mistenkelige e-poster og rapportering av avvik.

4. Detect

Detect handler hovedsakelig om å oppdage avvik og hendelser tidligst mulig. NordElektro kan ha opplevd at problemer ble oppdaget først etter at ansatte eller kunder meldte fra. Dette tyder på svak overvåkning. En kontinuerlig overvåkning er helt nødvendig når det er snakk om mange butikker og mange tilkoblede enheter.

NordElektro bør derfor etablere det vi kaller for «**continuous monitoring**» gjennom sentrale logginnsamling og korrelasjon: for eksempel i et SIEM-system. Logger fra POS-systemer, brannmurer, servere, databaser, skyplattformer og identitetsløsninger bør samles inn og analyseres fortløpende. Dette vil da gjøre det lettere for NordElektro å oppdage unormal trafikk, mistenkelige innlogginger, mislykkede autentiseringsforsøk, ukjente enheter og annen avvikende aktivitet.

NordElektro kan kombinere **nettverksovervåkning**, **NAC-løsninger** (Network Access Control), **trådløs overvåkning** og **segmentering** for å avdekke uautorisert trafikk. Hvis en ukjent enhet kobler seg til butikknettet, bør systemet automatisk flagge dette eller plassere enheten i det vi kaller for en «karantenesone». I tillegg kan NordElektro bruke baselining av normal trafikk for lettere å oppdage det som skiller seg ut.

5. Respond

Respond handler hovedsakelig om hvordan NordElektro vil håndtere en sikkerhetshendelse etter at den er oppdaget. NordElektro må ha en tydelig og dokumentert prosess for hendelseshåndtering med:

- klare roller
- ansvar
- eskaleringsveier.

Dette bør inkludere følgende:

- klassifisering av hendelser
- teknisk analyse
- isolering av berørte systemer
- intern kommunikasjon
- ekstern varslings og etterarbeid.

I NordElektro kan disse uklare roller ført til forsinkelser og dårlig koordinering. Derfor tenker NordElektro bør definere hvem som leder hendelseshåndteringen, hvem som tar tekniske beslutninger, hvem som kommuniserer med butikkleidere og hvem som dokumenterer tiltakene. Det må også være tydelig når ledelsen og juridisk funksjon skal kobles inn.

Dette er viktig å nevne at rask varsling er ekstra viktig. Ved en mulig betydelig hendelse må NordElektro ha en prosess som gjør det mulig å sende tidlig varsling innen lovpålagte frister og deretter følge opp med rapporter. For å få dette til i praksis kan NordElektor ha forhåndsdefinerte maler, kontaktpunkter og kriterier for hva som utløser rapportering.

6. Recover

Recover handler hovedsakelig om å gjenopprette normal drift og lære av hendelsen i etterkant. For NordElektor virket dette som en svak punkt, siden backup-rutiner og gjenoppretting beskrives som lite dokumentert og sjelden testet. Det er ikke nok å ha backup dersom ingen vet hvor raskt systemene kan gjenopprettes.

NordElektro bør derfor etablere en robust kontinuitets- og gjenopprettingsplan. Dette innebærer tydelige RTO- og RPO-mål for kritiske systemer, jevnlig testing av backup og restore, alternative salgsrutiner i butikk hvis sentralsystemene faller ut og øvelser som kan teste hele prosessen.

For å sikre at butikkene fortsatt kan selge varer etter en større systemsvikt, kan NordElektro for eksempel ha lokale nød prosedyrer, offline-funksjonalitet i POS-løsninger og reserverutiner for betaling. Poenget her er at NordElektor må kunne opprettholde et minimumsnivå av drift selv om deler av infrastrukturen ikke fungerer.

Task A2 - IAM, Zero Trust, RBAC og ABAC

NordElektro går fra et mer «tradisjonell» perimeterbasert sikkerhet til en mer Zero Trust-basert modell. Det betyr i prinsippet at NordElektro ikke skal stole på brukere eller enheter automatisk bare fordi de er «inne i nettverket». Hver tilgang skal da vurderes ut følgende:

- Identitet
- Rolle
- Kontekst
- Risiko
- behov.

For å kunne innføre **IAM** på en god måte må NordElektro først ha kontroll på identiteter, roller, systemer og prosesser. Det innebærer blant annet at NordElektor har en sentral identitetskilde, livssyklusstyring av kontoer, en tydelig rollemodell, sterk autentisering, policy-basert autorisasjon, logging og sporbarhet i tillegg til jevnlig tilgangsrevisjoner. Dette passer godt inn i en Zero Trust-modell, fordi tilgang hele tiden må og skal verifiseres og begrenses til det som er nødvendig.

RBAC betyr hovedsakelig at tilganger gis ut fra hvilken rolle en bruker har. Det gjør modellen enkel å forstå og administrere, og den passer godt i store organisasjoner der mange ansatte har like arbeidsoppgaver. Ulempen i vårt tilfelle er at RBAC kan bli for grov hvis

tilgangsbehovet varierer mye. Men en løsning som også kan implementeres er ABAC. Denne bygger derimot på flere attributter, som rolle, avdeling, lokasjon, tidspunkt og enhetsstatus. Dette kan gi NordElektro mer fleksibilitet og risikobasert tilgangsstyring, men er derimot mer komplisert å drifte.

For NordElektro vil det være best å kombinere RBAC og ABAC. RBAC kan brukes som grunnstruktur og ABAC kan brukes for å ta hensyn til kontekst og risiko. Et eksempel er forskjellen mellom en deltidsansatt lagerarbeider og en regional butikksjef. Lagerarbeideren trenger tilgang til lagerstatus og ordreplukk mens butikksjefen trenger oversikt over flere butikker, salgstall og rapportering. Vi kan tenke oss at dersom begge hadde fått samme tilgang, hadde dette brutt med prinsippet om minste privilegium, og det er noe vi ikke ønsker.

Prinsippet om minste privilegium betyr at en bruker bare skal ha tilgang til det som er nødvendig for å gjøre arbeidsoppgavene sine. Dette er viktig i et selskap som NordElektro siden brede rettigheter øker konsekvensene hvis en konto blir misbrukt. Administrative rettigheter bør derfor være svært begrenset og helst gis separat. Dette kommer med for eksempel ekstra autentisering og tidsbegrensning.

I en Zero Trust-modell må også kontekst påvirke tilgang. For NordElektro gjelder dette:

- lokasjon
- tidspunkt
- enhetshelse.

Innlogging for eksempel fra et land som ikke er Europa (la oss si for eksempel India), på et unormalt tidspunkt, bør enten kreve sterk kontroll (ekstra autentisering) eller bli rett og slett blokkert. Derfor bør virksomheten bruke det vi kaller for «**Conditional Access**», slik at lav risiko kan slippe gjennom, mens høyere risiko krever MFA eller ny autentisering.

Tre viktige kategorier fra OWASP Top 10 er:

- **Broken Access Control**
- **Authentication Failures**
- **Injection.**

Broken Access Control handler hovedsakelig om at brukere får tilgang til ressurser de ikke skal ha. Her kan IAM redusere risikoen gjennom tydelige roller, minste privilegium og jevnlig tilgangsrevisjoner.

Authentication Failures handler hovedsakelig om svakheter i innlogging og autentisering, som svake passord eller manglende MFA. Her er IAM viktig gjennom sterk autentisering, gode passordregler og risikobasert innlogging.

Injection skyldes usikker håndtering av input. Viktig å påpeke at selv om dette må løses i applikasjonen, kan IAM begrense skadeomfanget ved å sørge for at kompromitterte kontoer eller tjenester ikke har for brede rettigheter.

Task A3.1 – Informasjonseiendelsregister

For **Click & Collect-løsningen** er det viktig å finne ut hvilke verdier som må beskyttes. Det gjelder både informasjonsverdier, støtteverdier og immaterielle verdier.

Kundeopplysninger er et klart eksempel for det vi kaller informasjonsverdier. Dette kan være alt fra navn, telefonnummer, e-postadresse, leverings- eller hentested til eventuelt personnummer. Her kan leder for kundedata for eksempel være **asset owner**, fordi dette er sensitiv informasjon som må beskyttes mot uautorisert tilgang og misbruk. Et annet eksempel er transaksjons- og bestillingshistorikk. Det kan være ordrenummer, kjøpstidspunkt, betalingsstatus, returhistorikk eller hentestatus. Her kan leder for e-handel være **asset owner**, siden disse dataene er en viktig del for drift, kundeservice og håndtering av reklamasjoner.

Den skybaserte SQL-databasen for Click & Collect er en viktig ressurs, og kan da klassifiseres under støtteverdier. Her kan databaseansvarlig være **asset owner** fordi databasen lagrer informasjonen og gjør den tilgjengelig for tjenesten.

- POS-terminaler og butikkens utleveringsenheter er også viktige støtteverdier. Her kan for eksempel butikkdriftssjef være **asset owner** siden disse enhetene brukes til å hente ordrestatus, bekrefte utlevering og registrere salg, osv..

Blant de immaterielle verdiene er noe som ikke kan kjøpes og er vanskelig å sammenligne med det vi har snakket om hittil, nemlig omdømme. Her kan for eksempel kommunikasjonssjef være **asset owner** fordi et sikkerhetsbrudd kan skade tilliten til NordElektro langt mer enn bare den tekniske feilen i seg selv. Kundetillit spiller også en veldig viktig del her. Her kan leder for kundeopplevelse være **asset owner** fordi kundene må kunne stole på at opplysninger og bestillinger blir behandlet trygt og riktig.

Med dette kan vi konkludere med at det er ekstremt viktig å ha en tydelig asset owner. Hvis eierskapet blir for generelt, blir også ansvaret uklart. Når en bestemt person har ansvar for en eiendel blir det også lettere å klassifisere den riktig, vurdere den gitte risiko og prioritere hendelsen etter viktighet. Dette passer også godt med Govern-funksjonen i NIST CSF 2.0, siden den handler om tydelig styring, roller og ansvar.

Task A3.2 - Risiko: sårbarhet, trussel aktør og konsekvens for CIA-triaden

I denne delen fokuserer jeg på eiendelen **Customer SQL Database**.

Sårbarhet

En aktuell sårbarhet i vår case kan være dårlig inputvalidering i webapplikasjonen, noe som kan gjøre databasen utsatt for SQL-injeksjon. Hvis applikasjonen ikke bruker parameteriserte spørringer eller andre sikre metoder for å håndtere input, kan ondsinnet data bli tolket som vanlige databasekommandoer, og gjøre systemet vårt sårbar.

Trussel aktør

En relevant trussel aktør er en ekstern cyberkriminell som leter etter svakheter i nettbutikken og kundeportaler for å stjele kundeinformasjon eller presse virksomheten vår for penger.

Trussel scenario

En trussel scenario NordElektro kan møte er ved lanseringen av en ny Click & Collect-løsning som er koblet til nettbutikken og den sentrale kundedatabasen. I juleperioden er trafikken veldig høy i de fleste nettbutikker rundt i Norge. Vi kan tenke oss at vi gir ut den nye løsningen og oppdager at et felt i bestillingsskjemaet er ikke godt nok sikret. En angriper kan fort oppdage dette og sende inn SQL-kode som systemet ikke klarer å stoppe. Angriperen kan da bruke sårbarheten til å hente ut kundeopplysninger og transaksjonshistorikk. Videre kan personen endre ordrestatus for å skjule det som skjer eller forstyrre driften. I verste fall kan angriperen sende inn tunge SQL-spøringer som gjør databasen treg eller utilgjengelig. Dette er et realistisk scenario, spesielt hvis applikasjonen har for brede rettigheter og vi har bygget systemet med en svak overvåkning.

Vurdering opp mot CIA-triaden

Konfidensialitet

Konfidensialiteten kan bli svekket dersom en angriper får tilgang til kundeopplysninger, ordreda eller annen sensitiv informasjon. Dette kan føre til brudd på personvernet, redusert tillit fra kundene og mulige juridiske konsekvenser. I tillegg kan informasjonen brukes videre til phishing eller annen svindel.

Integritet

Integriteten kan bli svekket dersom en angriper endrer data, for eksempel ordrestatus, kundedata eller transaksjonsposter. Dette kan føre til feil utleveringer, problemer i kundeservice og feil i rapporteringen. Selv små endringer kan få store konsekvenser når de påvirker viktige deler av driften.

Tilgjengelighet

Tilgjengeligheten kan bli svekket dersom databasen blir treg, låses eller må tas ned på grunn av skadelige spøringer eller arbeid med gjenoppretting. Da kan Click & Collect stoppe opp. Med dette kan det føre til at kundene får ikke hentet varene sine og at butikken mister oversikten over bestillingene. Dette kan føre til økonomiske tap, økt press på kundeservice og skade på virksomhetens omdømme.

Delkonklusjon for A.3

Sett fra et ISO 27001-perspektiv viser dette at informasjonssikkerhet ikke bare handler om teknologi, men også om struktur, eierskap og sporbarhet. Ved å tydelig identifisere eiendeler og ved å gi dem tydelige eiere og analysere sammenhengen mellom sårbarhet og trussel, kan NordElektro få et bedre grunnlag for å velge riktige sikkerhetstiltak i Click & Collect-løsningen sin.

Task B – Kryptografipolicy

Sikker bruk av kryptografi er viktig for NordElektros sentraliserte database. I denne delen forklarer jeg hvordan tre typer data bør beskyttes: brukeropassord, norske personnummer og transaksjonshistorikk. Jeg deler dette inn i data at rest, data in transit og future proffing.

1. Data at Rest

Passord – hashing med salt

Brukerpassord skal aldri lagres med vanlig kryptering som kan gjøres om tilbake til klartekst. I stedet bør de lagres med enveis hashing og salt, for eksempel med Bcrypt eller PBKDF2. Grunnen til dette er at systemet ikke trenger å vite hva det opprinnelige passordet er, bare om passordet brukeren skriver inn stemmer med det som er lagret. Dette vet jeg er et veldig ofte bruk teknikk i nettsider med høy trafikk.

Hashing er derfor riktig metode for passord, fordi de ikke skal kunne dekrypteres. Hvis passord hadde vært lagret med symmetrisk kryptering, kunne de i verste fall blitt lest dersom nøkkelen ble «leaked». Salt er i dette tilfelle også veldig viktig fordi det gjør at to brukere med samme passord får ulike hashverdier. Det gjør angrep som rainbow tables mindre effektive. I tillegg bør man bruke tregere algoritmer som Bcrypt eller PBKDF2, fordi det gjør brute force-angrep enda vanskeligere.

Personnummer – symmetrisk kryptering

Personnummer er en type data som i noen tilfeller skal kunne leses tilbake av autoriserte brukere eller systemer. Derfor passer ikke hashing her. I stedet bør NordElektro bruke symmetrisk kryptering, for eksempel AES-256-GCM.

AES-GCM beskytter både konfidensialitet og integritet. Det betyr at dataene både krypteres og at det blir mulig å oppdage om de er blitt endret. For NordElektro betyr dette at personnummer bør lagres kryptert i databasen, sammen med streng nøkkelhåndtering, tilgangskontroll og logging. Kryptering alene er ikke nok hvis nøklene ikke forvaltes sikkert.

Transaksjonshistorikk

Transaksjonshistorikk kan inneholde både forretningskritisk informasjon og personopplysninger og bør derfor beskyttes når den lagres. Her tenker jeg at det mest naturlig ting å bruke er symmetrisk kryptering for sensitive felter eller diskryptering og databasenivå-kryptering sammen med tilgangsstyring og logging. Disse dataene må ofte brukes til analyse, reklamasjoner eller kundeservice, så hashing passer ikke her. Samtidig er det viktig å beskytte integriteten, slik at historikken ikke kan endres uten at det blir oppdaget (for eksempel mange som vil da prøve å få meg seg gratis varer).

Forslag til policy

Passord bør bare lagres som saltede hashverdier, for eksempel med Bcrypt eller PBKDF2. Personnummer bør lagres kryptert med AES-256-GCM og beskyttes med streng

nøkkelhåndtering. Transaksjonshistorikk bør lagres kryptert der sensitiviteten krever det, særlig felter som kan knyttes til kunder eller betalinger.

2. Data in Transit – hvorfor TLS 1.3 bør brukes

NordElektro bør bruke TLS 1.3 for all kommunikasjon, fordi denne versjonen er sikrere enn eldre versjoner. En viktig fordel er at TLS 1.3 har fjernet gamle og svake løsninger og heller bruker moderne algoritmer. Dette reduserer risikoen for feiloppsett og gjør det enklere å bruke protokollen på en sikker måte.

En annen fordel er at TLS 1.3 har fjernet flere eldre handshake-mekanismer som tidligere har vært sårbare eller vanskelige å konfigurere riktig. Det gjør protokollen sterkere og reduserer angrepsflaten. Dette betyr i hovedsak bedre beskyttelse av kommunikasjonen mellom nettbutikken, API-er, butikkterminaler og sentrale systemer.

3. Future-Proofing – Perfect Forward Secrecy (PFS)

Perfect Forward Secrecy betyr at selv om en privat nøkkel skulle bli kompromittert senere, skal det fortsatt ikke være mulig å dekryptere gammel nettverkstrafikk. Dette er viktig fordi angripere kan samle inn kryptert trafikk over tid og prøve å lese den senere.

NordElektro kan bruke ECDHE til nøkkelutveksling. Det blir da laget midlertidige sesjonsnøkler for hver enkelt forbindelse. Disse nøklene er ikke de samme som serverens faste private nøkkel. Derfor vil ikke et senere kompromiss av servernøkkelen automatisk gi tilgang til tidligere sesjoner. Dette er spesielt viktig for NordElektro fordi virksomheten sender kundedata, ordreinformasjon og interne prosesser mellom mange ulike systemer. PFS gir derfor ekstra beskyttelse og reduserer risikoen for langsiktig skade.

Verktøy

Jeg har brukt KI kun til språklig forbedring og strukturering. Det faglige innholdet er basert på forelesninger, pensum og oppgitte kilder, og jeg har selv gjennomgått og bearbeidet hele besvarelsen. Jeg kan forklare innholdet muntlig ved behov.

- **Text correction:** Ja
- **Text generation:** Nei
- **Writing assistance:** Nei
- **Image generation:** Nei

Kilder

- NIST. *Cybersecurity Framework (CSF) 2.0*.
- ISO/IEC 27001:2022. *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*.
- OWASP Foundation. *OWASP Top 10*.

- Dierks, T. & Rescorla, E. / IETF RFC 8446. *The Transport Layer Security (TLS) Protocol Version 1.3*.
- Forelesningssides i emnet.
- Pensumlitteratur oppgitt i emnet.